



Addis Ababa University
College of Natural and Computational Sciences
Department of Computer Science
Computer Networking and Security Module

Part I: Data Communication and Computer Networking

Part II: Network and System Administration



Part III: Computer Security

May 2024
Addis Ababa,
Ethiopia

Chapter 1: Information/Computer Security Issues

1. Introduction

- **Security** is “the quality or state of being secure—to be free from danger.”
 - in other words, protection against adversaries —from those who would do harm, intentionally or otherwise—is the objective.
 - **National security**, for example, is a multilayered system that protects the sovereignty of a state, its assets, its resources, and its people. Achieving the appropriate level of security for an organization also requires a multifaceted system.

2. Information Assurance?

- The practice of assuring information and managing risks related to the use, processing, storage, and transmission of information or data, the systems and processes used for those purposes.
- Includes protection of the integrity, availability, authenticity, non-repudiation and confidentiality of user data.
 - Using physical, technical and administrative controls to accomplish these tasks.
 - not only digital but also analog or physical form
- Includes restoration of information systems by incorporating protection, detection, and reaction capabilities.
- It is best thought of as a superset of information security, strongly related to the field of information security, and also with business continuity.

3. Why Information Assurance is needed?

- To protect information exchanges between interconnected computer systems.
 - Stand-alone COMPUSEC could not protect information during storage, processing or transfer between systems.
 - to detect attacks and enable a response to those attacks
- To add business benefit through the use of IRM (Information Risk Management).
 - improves business continuity
- Generally, to minimize risk and ensure business continuity by implementing controls to limit the impact of a security breach.

4. Information Assurance pillars

- **Confidentiality:**
 - Preserving authorized restrictions on access and disclosure.
 - Includes personal privacy and proprietary information protection.
- **Integrity:**
 - protecting against improper information modification or damage

- The data stored on the computer is the same as what is intended.

➤ **Availability:**

- Ensuring timely and reliable access to and use of information.
- Assures systems work promptly & service isn't denied to authorize users.

➤ **Authentication:**

- Is proving a claim – usually that you are who you say you are.

➤ **non-repudiation:**

- Prevention of either the sender or receiver denying a transmitted message.
- Prove the occurrence of a claimed event or action and its originating entities.

5. Information Assurance strategy

- Cyber security awareness and education
- Strong cryptography
- Good security-enabled commercial information technology
- An enabling global Security Management Infrastructure; and
- A civil defense infrastructure equipped with an attack sensing and warning capability and coordinated response mechanism

6. Difference: InfoSec, computer security & IA

- **IA:** measures that protect and defend information and ISs by ensuring their availability, integrity, authentication, confidentiality, and non-repudiation.
- Information protection or **InfoSec:** protection of information and ISs from unauthorized access, use, disclosure, disruption, modification, perusal, inspection, recording or destruction.
- **Computer Security:** (W. Stallings)
 - Protection to an automated information system in order to attain the applicable objectives of preserving the confidentiality, integrity, and availability (CIA) of information system resources (includes hardware, software, firmware, information/data, and telecommunications).
- Two major aspects of **InfoSec** are:
 - **IT security** (Sometimes **computer security**): is InfoSec applied to technology (most often computer system).
 - **IA:** The act of ensuring that data is not lost when critical issues like natural disasters, system malfunction, physical theft, etc. arise.
- **InfoSec, computer security & IA** are frequently used interchangeably;
 - These fields are interrelated and share the common goals of protecting the CIA of information; however, there are some subtle differences.
 - differences lie primarily in the approach to the subject, the methodologies used, and the areas of concentration.

- **InfoSec:** concerned with the CIA of data regardless of the form the data may take: electronic, print, or other forms.
- **Computer security:** can focus on ensuring the availability and correct operation of a computer system without concern for the information stored or processed by the computer.
- **IA:** focuses on the reasons for assurance that information is protected, and is thus reasoning about information security.

7. Enterprise security & Cyber defense

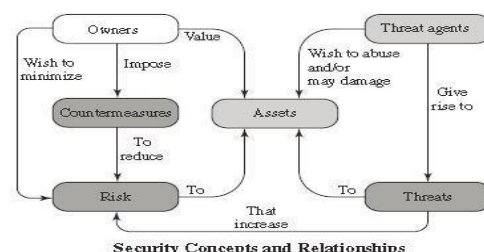
- **Enterprise security:** is about building systems to remain dependable in the face of malice, error, or mischance.
- **Cyber defense:** computer network defense mechanism which includes response to actions and critical infrastructure protection and IA for possible networks.
- **Business-driven approach** to enterprise security architecture means that security is about enabling the objective of an organization by controlling operational risk.

8. Threats, vulnerabilities, risk, controls (W. Stallings)

- **Adversary (threat agent):** An entity that attacks, or is a threat to, a system. e.g. all hackers in the world
- **Threat:** any circumstances or events that can potentially harm an information system by destroying it, disclosing the information stored on the system, adversely modifying data, or making the system unavailable.
- **Vulnerability:** weaknesses or fault in an information system or its components that could be exploited.
- **Attack:** actual violation of security that derives from an intelligent threat.
- **Risk:** An **expectation of loss** expressed as the probability that a particular threat will exploit a particular vulnerability with a particular harmful result.
 - $\text{Risk} = \text{Threats} \times \text{Vulnerabilities}$
- **Control, safeguard, or countermeasure:** An action, device, procedure, or technique that reduces a threat, a vulnerability, or an attack by eliminating or preventing it, by minimizing the harm it can cause, or by discovering and reporting it so that corrective action can be taken.
- **Security Policy:** A set of rules and practices that specify or regulate how a system or organization protects sensitive and critical system resources.
- **System Resource (Asset):** Data contained in an information system; or a service provided by a system; or a system performance; or an item of system equipment (i.e., a system component—hardware, software, or documentation); or a facility that houses system operations and equipment.

Chapter 2: Information security models and mechanisms

1. Model for Computer Security



- **Example:** If a company has antivirus software but does not use an anti-virus and keep the virus signatures up-to-date, this is vulnerability. The company is vulnerable to virus attacks. Similarly, if you fail to routinely update your operating systems or application software, these will remain vulnerable to software problems ("bugs") that have been identified and patched

- **Vulnerability:** no antivirus/ un updated Signatures
- **Threat:** Virus
- **Attack:** System Crash and/or destroy data and/or data modification
- The likelihood of a virus showing up in the environment and causing damage is the **risk**.
- The countermeasures in this situation are to update the signatures and install the antivirus software on all computers

2. Goals of computer security

3 key objectives of computer security: CIA triad (W. Stallings)

- **Confidentiality:** Data confidentiality and Privacy
 - is the prevention of unauthorized disclosure of information.
 - In other words, confidentiality means keeping information private or safe.
 - it may be important for military, business or personal reasons.
 - it may also be known as privacy or secrecy.
- **Integrity:** covers Data integrity and System integrity
 - the prevention of unauthorized writing or modification of information.
 - Integrity in a computer system means that there is an external consistency in the system – everything is as it is expected to be.
 - Data integrity: the data stored on the computer is the same as what is intended.
- **Availability:**
 - Assures that systems work promptly and service is not denied to authorized users.
 - Information should be accessible and usable upon appropriate demand by an authorized user.

- **Denial of service (DOS) attacks** are a common form of attack against computer systems whereby authorized users are denied access to the computer system.

Additional objectives:

- **Non-repudiation:** is the prevention of either the sender or the receiver denying a transmitted message.
 - It is the ability to prove the occurrence of a claimed event or action and its originating entities
 - It assures that a **sender** of data is provided with proof of delivery and the **recipient** is provided with proof of the sender's identity, so neither can later deny having processed the data.
 - often implemented by using **digital signatures**
- **Authentication**
 - is proving a claim – usually that you are who you say you are.
 - for example it may be obtained by the provision of a password or by a scan of your retina.
- **Access controls**
 - provide the limitation and control of access to authorized users through identification and authentication.
 - A system needs to be able to identify and authenticate users for access to data, applications and hardware.
 - In a large system there may be a complex structure determining which users and applications have access to which objects.
- **Accountability**
 - Ensuring an entity's action is traceable uniquely to that entity.
 - Ascertains the responsibility of an entity (like a person) for its actions and decisions.
 - All relevant activities events and operations on a system, e.g., failed and successful authentication attempts, are recorded in a log.

3. Security Attack

- The agent carrying out the attack is referred to as an **attacker**, or **threat agent**.
- We can distinguish two types of attacks: (W. Stallings)
 - **Active attack:** an attempt to alter/affect system resources or their operation.
 - **Passive attack:** an attempt to learn/make use of information from the system that does not affect system resources.
- We can also classify attacks based on the origin of the attack:
 - **Inside attack:** Initiated by an entity inside the security perimeter (an "insider").
 - **Outside attack:** Initiated from outside the perimeter.
- **Types of Attacks on Data CIA (W. Stallings)**
 - **Disclosure/Interception:** unauthorized party snooping, or getting access to a resource, Attack on data confidentiality:

- **Modification / Deception:** unauthorized party modifying a resource, acceptance of false data, E.g., providing wrong data (attack on data integrity)
- **Disruption/Interruption:** destroyed/unavailable services/resources, DoS (attack on data availability)
- **Fabrication:** unauthorized party inserts a fake asset/resource, loss of confidentiality, authenticity and integrity of the message

▪ Types of Attackers

- **Amateurs:** Opportunistic attackers (use a password they found), Script kiddies
- **Hackers** - nonmalicious
- **Crackers** – malicious
- **Career criminals**
- State-supported spies and information **warriors**

4. Countermeasure Methods to Risk

- Any means taken to deal with a security attack. It can be devised to prevent a particular type of attack. When prevention is not possible, or fails in some instance, the goal is to detect the attack and then recover from the effects of the attack.
- Five basic approaches to defense of computing systems
 - **Prevent attack:** from violating security policy, Block attack / Close vulnerability
 - **Deter attack:** intended to discourage potential attackers, Make attack harder,
 - **Deflect attack:** Make another target more attractive than this target
 - **Detect attack:** accept that an attack will occur; the goal is to determine that an attack is under way, or has occurred, and report it.
 - **Recover from attack:** Stop attack, assess and repair damage or restore the operations of the business

5. Controls: Security policies & mechanisms

- for Today Computers
 - **Encryption:** primary control that protects CIA, by which Cleartext scrambled into ciphertext.
 - **Software controls:** password checker, virus scanner, IDS (intrusion detection system)
 - **Hardware controls:** provide higher degree of security; Locks, Smart cards, dongles, hardware keys...
 - **Policies and procedures:** Alignment with users' legal and ethical standards; eg. password policy
 - **Physical controls:** natural and man-made disaster protection; walls, locks, guards, security, cameras, backup copies and archives

6. Principles of Computer Security

- Principle of Easiest Penetration
- Principle of Adequate Protection
- Principle of Effectiveness: Controls must be efficient, easy to use, and appropriate.
- Principle of Weakest Link: Security can be no stronger than its weakest link.

- Principles of Least Privilege: “Do not give any more privileges than absolutely necessary to do/perform the required job”.
- Defense in Depth: having more than one layer or type of defense
- Minimization: “do not run any software, or applications that are not strictly required to do the entrusted job.”
- Compartmentalization: limits the damage in other compartments when one compartment is compromised.
- Keep Things Simple: Complexity is the worst enemy of security.
- Fail Securely: if a security measure or control has failed for whatever reason, the system is not rendered to an insecure state.
- Balancing Security and Access

Chapter 3: Computer Threats/Attacks

1. Types of Threats/Attacks ... (Chuck Eastom)

- **Physical Attack:** Stealing, breaking or damaging of computing devices
- **Malware Attack:** A generic term for software that has malicious purpose.
 - Viruses
 - Worms
 - Trojan horses
 - Spy-ware
 - Zombie
 - Botnets
 - Bacterium
 - Logic bomb
 - Backdoor(Trapdoor)
 - Adware
 - Flooders (DoS client)
 - Key loggers
 - Rootkit
 - Spam/scam, identity theft, e-payment frauds, etc.
- **Hacking /Intrusion/ Attack:** any attempt to intrude or gain unauthorized access to your system either via some operating system flaw or other means. The purpose may or may not be for malicious purposes.
- **Cracking:** is hacking conducted for malicious purposes.
- **Denial of Service (DoS) Attack:** Blocking access from legitimate users
- **Distributed DoS Attack:** is accomplished by tricking routers into attacking a target or using Zombie hosts to simultaneously attack a given target with large number of packets.
- **Spoofing:** Examples; MAC cloning, IP spoofing, and email spoofing
- **Password attacks:** guessing password; social engineering attack, Dictionary attack
- **Cryptographic Attack:**
 - A. **Frequency Analysis attack:** Guess values based on frequency of occurrence

- B. **Brute-force attack:** The attacker tries every possible key on a piece of ciphertext until an intelligible translation into plaintext is obtained. On average, half of all possible keys must be tried to achieve success.
- C. **Cryptanalysis:** the process of breaking an encrypted code.
 - ✓ Ciphertext only Attack, Known plaintext Attack, Chosen plaintext Attack, Chosen ciphertext Attack, and Chosen text Attack

2. Class of Attacks

- **Reconnaissance:** The hackers first identifies a target to launch an attack, extract maximum information regarding this target, understand its vulnerabilities, and then only explore the best ways to exploit it.
 - **Examples: Credential Theft** using Keyloggers and Spyware; **Identity Theft** using spam e-mail, phishing attack and social engineering attack
- **Access:** Ones the attacker Reconnaissance the target, S/he starts a successful exploitation and continued access to the system. Then, the attacker is in control of the target.
- **Denial of Service:** Ones the attacker having a successful access to the system. S/he starts to deny users from accessing or using the service or system.

Chapter 4: Application of Security Mechanisms

1. Cryptography and hash functions

- **Cryptography** is the science and art of secret, or hidden writing
- **Cryptanalysis** is the science and art of breaking codes.
- **Modern cryptography concerns with:**
 - **Confidentiality** - Information cannot be understood by anyone.
 - **Integrity** - Information cannot be altered.
 - **Non-repudiation** - Sender cannot deny his/her intentions in the transmission of the information at a later stage.
 - **Authentication** - Sender and receiver can confirm each.
- Generally, the goal of the cryptography is to protect private communication in the public world.
- **Basic cryptographic terms**
 - **Plaintext** - the original form of a message
 - **Ciphertext** - the coded/encrypted form of a message
 - **Cipher** – an encryption method or process encompassing the algorithm and key, or procedures used to transform plaintext to ciphertext
 - **Key** - info used in cipher known only by the sender/receiver. A **Key** is value that the cipher, as an algorithm, operates on.
 - ✓ If **same key** is used **for encryption & decryption** the algorithm is called **symmetric**
 - ✓ If **different keys** are used **for encryption & decryption** the algorithm is called **asymmetric**

- **Encipher (encrypt)** – the process of converting plaintext to ciphertext
- **Decipher (decrypt)** - recovering plaintext from ciphertext
- **Cryptography** – the study of encryption principles/methods
- **Cryptanalysis (codebreaking)** - the study of principles/ methods of breaking ciphertext *without* knowing key
- **Cryptology** - the field of study which deals with both cryptography and cryptanalysis
- **Cryptography classification:**
 - A. **Classical/Conventional Cryptography:** Substitution Cipher and Transposition Cipher
 - B. **Modern Cryptography:** Symmetric key cryptography and Public key cryptography

Classical Cryptography

Substitution ciphers

- Replaces one symbol with another.
- Categories monoalphabetic or polyalphabetic ciphers.

(1) Monoalphabetic Ciphers

- The relationship between a symbols in the plaintext to a symbol in the ciphertext is always **one-to-one**.
- sometimes called additive cipher or shift cipher or Caesar cipher (key of 3)
- When the cipher is **additive**, the **plaintext**, **ciphertext**, and **key** are integers in $\mathbb{Z}_{26}$.
- **Exercise:**
 - ✓ Use **additive cipher** with **key = 15** to **encrypt** the message “hello”.
 - ✓ Use the **additive cipher** with **key = 15** to **decrypt** the message “WTAAD”.
- **Multiplicative Ciphers:** the plaintext and ciphertext are integers in $\mathbb{Z}_{26}$; the key is an integer in $\mathbb{Z}_{26}^*$. This set has only 12 members: 1, 3, 5, 7, 9, 11, 15, 17, 19, 21, 23, 25.
- **Exercise:**
 - ✓ use a **multiplicative cipher** to **encrypt** the message “hello” with a **key of K=7**. The ciphertext is “XCZZU”.
 - ✓ Decryption key is multiplicative inverse of $K=7$; $K^{-1} \bmod 26 = 7^{-1} \bmod 26$.
- **Affine Ciphers:** uses a pair of keys in which the first key is from $\mathbb{Z}_{26}^*$ and the second is from $\mathbb{Z}_{26}$. The size of the key domain is $26 \times 12 = 312$.
 - ✓ The **additive cipher** is a special case of an affine cipher in which $k_1 = 1$. The **multiplicative cipher** is a special case of affine cipher in which $k_2 = 0$.
- Because additive, multiplicative, and affine ciphers have **small key domains**, they are very vulnerable to **brute-force attack**;
 - ✓ Solution: Monoalphabetic Substitution Cipher
- **Monoalphabetic Substitution Cipher:** creates a mapping between each plaintext character and the corresponding

ciphertext character. Alice and Bob can agree on a table showing the mapping for each character.

Plaintext	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
Ciphertext	N	O	A	T	R	B	E	C	F	U	X	D	Q	G	Y	L	K	H	V	I	J	M	P	Z	S	W

(2) Polyalphabetic Ciphers

- The relationship between a character in the plaintext to a character in the ciphertext is **one-to-many**.
- **Autokey Cipher:**

$$P = P_1 P_2 P_3 \dots \quad C = C_1 C_2 C_3 \dots \quad k = (k_1, P_1, P_2, \dots)$$

$$\text{Encryption: } C_i = (P_i + k_i) \bmod 26 \quad \text{Decryption: } P_i = (C_i - k_i) \bmod 26$$

- Playfair Cipher
- Vigenere Cipher
- **Exercise:**
 - ✓ **Encrypt** the message “She is listening” using the 6-character keyword “PASCAL”.
 - ✓ The initial key stream is (15, 0, 18, 2, 0, 11). The key stream is the repetition of this initial key stream (as many times as needed)
- **Hill Cipher:**
 - ✓ Key in the Hill cipher: The key matrix in the Hill cipher needs to have a multiplicative inverse.

$$K = \begin{bmatrix} k_{11} & k_{12} & \dots & k_{1m} \\ k_{21} & k_{22} & \dots & k_{2m} \\ \vdots & \vdots & & \vdots \\ k_{m1} & k_{m2} & \dots & k_{mm} \end{bmatrix}$$

$$\begin{aligned} C_1 &= P_1 k_{11} + P_2 k_{21} + \dots + P_m k_{m1} \\ C_2 &= P_1 k_{12} + P_2 k_{22} + \dots + P_m k_{m2} \\ &\dots \\ C_m &= P_1 k_{1m} + P_2 k_{2m} + \dots + P_m k_{mm} \end{aligned}$$

Transposition Ciphers

- Does not substitute one symbol for another, instead it changes the location of the symbols (reorders symbols).
- A transposition cipher relies on an algorithm which **rearranges the order of the letters in a plaintext message**

(1) Keyless Transposition Ciphers

- Permute the characters by writing plaintext in one way and reading it in another way.
- **rail-fence transposition:** a plaintext message is **transposed** into several **rows**
 - ✓ Ciphertext is produced by **reading** the resulting **columns** in sequence
 - ✓ Example with 2 rails (rows):
 - **Plaintext:** THEBIGBANGTHEORY
 - Plaintext arranged into 2 rows:
 - ✦ THEBIGBA
 - ✦ NGTHEORY

➤ **Ciphertext:** tnhgetbhiegobray

- **columnar transposition:** a plaintext message is **transposed** into several **columns**

✓ Ciphertext is produced by **reading** the resulting **rows** in sequence

✓ Example with 2 columns:

➤ **Plaintext:** SECRET

➤ Plaintext arranged into 2 columns:

S R

E E

C T

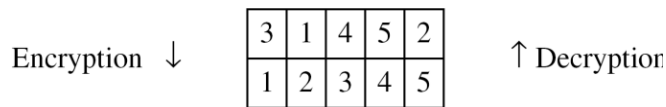
➤ **Ciphertext:** sreect

✓ The **key** in a columnar transposition is the **number of columns!**

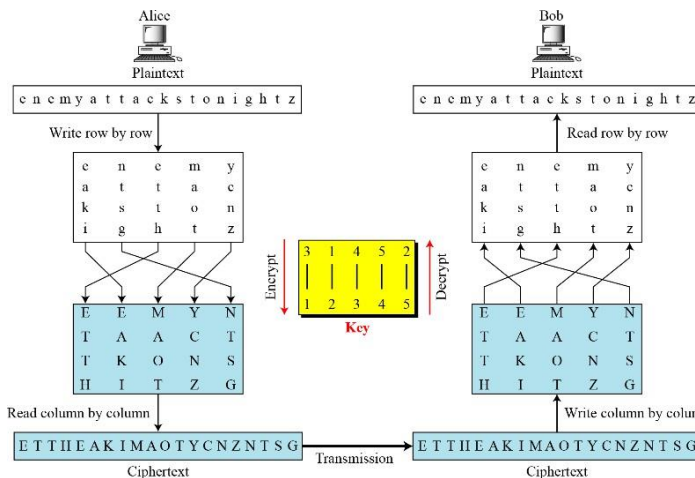
✓ In the example above, the **key is 2**

(2) Keyed Transposition Ciphers

- Is to divide the plaintext into groups of predetermined size, called blocks, and then use a key to permute the characters in each block separately.
- The permutation of each character in the plaintext into the ciphertext **based on the positions**.
- **Permutation key:** key used for encryption and decryption.



(3) Combining Two Approaches



Modern Cryptography:

- Based on Kerckhoff's principle, one should always assume that the adversary, Eve, knows the encryption/decryption algorithm.
- The **resistance of the cipher** to attack must be based only on the **secrecy of the key** and the **strength of the algorithm**.
- If the strength of the **algorithm is secured** enough, better way to break the cryptosystem will be trying every possible key in a **brute-force attack**.

- complexity of a brute-force attack:

- If the key is 56 bits long, there are 2^{56} possible keys.
- Assuming a supercomputer can try a million keys a second, it will take 2285 years to find the correct key.
- $2^{56} / (1000,000 * (365 \text{ days} * 24 \text{ hr} * 3600 \text{ s}))$
e.g. DES
- There are three main types of modern cryptographic functions that are the building blocks of security:
 - 1) symmetric encryption
 - 2) Asymmetric encryption
 - 3) Hash Functions

Symmetric key cryptography

- Uses conventional / secret-key / single-key.
- The secret key shared by both sender and receiver.
- All classical encryption algorithms are private-key.
 - Use the same key (shared key) for encryption and decryption process.
- If this key is disclosed communications are compromised.
- **Symmetric Cipher Model**
 - Alice can send a message to Bob over an insecure channel
 - ✓ with the assumption that an adversary, Eve, cannot understand the contents of the message.
 - The original message from Alice to Bob is referred to as plaintext;
 - the message that is sent through the channel is referred to as the cipher text.
 - Alice uses an encryption algorithm and a shared secret key.
 - Bob uses a decryption algorithm and the same secret key.

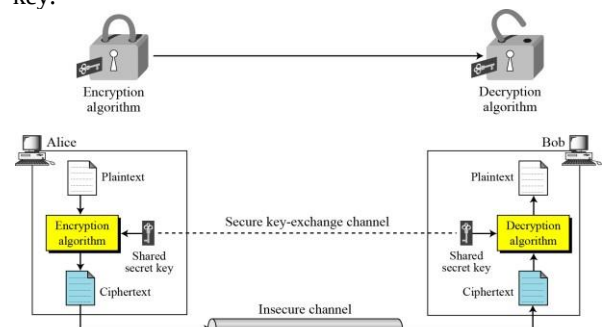


Figure 4.1 symmetric - key cryptography

- **2 requirements for secure use of symmetric encryption:**
 - Strong encryption algorithm: i.e., $Y = E_K(X)$
 - Secret key known only to sender / receiver: i.e. $X = D_K(Y)$
- Assume encryption algorithm is known
 - Implies a secure channel to distribute key:
 - ✓ Problem: - Key distribution problem
- **Key Distribution**
 - Symmetric schemes require both parties to share a common secret key.
 - Issue is how to securely distribute this key.

- Often secure system failure due to a break in the key distribution scheme.
- Given parties A and B have various key distribution alternatives:
 - A can select key and physically deliver to B.
 - Third party can select & deliver key to A & B.
 - If A & B have communicated previously can use previous key to encrypt a new key.
 - If A & B have secure communications with a third-party C, C can relay key between A & B.
- **Key Hierarchy**
 - **session key**
 - ✓ temporary key
 - ✓ used for encryption of data between users
 - ✓ for one logical session then discarded
 - **master key**
 - ✓ used to encrypt session keys
 - ✓ shared by user & key distribution center
- **Advantage:** Simpler and faster
- **Disadvantages:** Less secured, key exchange problem, large number of keys are needed
- **Examples of symmetric key algorithms are as follows:**
 - (1) **Data Encryption Standard (DES)** (56bits key)
 - **Feistel cipher:** half of the data block is used to modify the other half of the data block and then the halves are swapped.
 - passes through an initial permutation (IP) that rearranges the bits to produce the permuted input.
 - followed by sixteen rounds of the same function: involves both permutation and substitution functions.
 - The left and right halves of the output are swapped to produce the preoutput.
 - The preoutput passed through the inverse of the initial permutation function (IP^{-1})

- 64 Bit Block Length
- 56 Bit key Length
- 16 Rounds
- 48 bits of key used each round (subkey)
- Each Round is simple (for a block cipher)
- Security depends primarily on "S-Boxes"
- Each S-boxes maps 6 bits to 4 bits

(2) **Triple DES (3DES)** (168 bits key)

(3) **Advanced Encryption Standard (AES)**

- is not a Feistel structure
 - ✓ **processes the entire data block** as single matrix during each round using substitutions and permutation (**substitutions permutation Network**)
- plain text is a fixed block size of 128 bits and a key size of 128, 192, or 256 bits

- **Four different stages** are used, **one of permutation** and **three of substitution**:
 - ✓ **Substitute bytes:** Uses an S-box to perform a byte-by-byte substitution of the block
 - ✓ **ShiftRows:** A simple permutation
 - ✓ **MixColumns:** A substitution that makes use of arithmetic over GF(28)
 - ✓ **AddRoundKey:** A simple bitwise XOR of the current block with a portion of the expanded key
- Categories of symmetric ciphers:
 - **Stream Ciphers:** Encrypt data **one bit or one byte** at a time
 - **Block Ciphers:** a group of plaintext characters of a **fixed size (a block)** is encrypted at once and sent to the receiver; Playfair, Hill ciphers, modern symmetric ciphers
 - **Combination Cipher**

Asymmetric key cryptography

- also known as public-key encryption.
- **In public key cryptography,**
 - unlike symmetric-key, there are **two keys**: a private key and a public key.
 - ✓ The public key is announced to the public; whereas the private key is kept by the receiver.
 - anyone can send messages using the **public key** of the receiver for encryption, but only the receiver uses his **private key** for decryption
 - ✓ **Secret transmission of key** for decryption is not required
 - ✓ Every entity can generate a key pair and **release its public key**
 - ✓ Encryption and decryption keys are different **but form a unique pair**
 - **Note that:** Private key can also be public by keeping public key secret
- PKE systems **eliminate the problems(key exchange)** encountered with symmetric key systems
 - Key distribution is easy with PKE!
- used for confidentiality, authentication & Digital Signature.
- the padlock that is locked with a public key can be unlocked only with the corresponding private key.
- Eve should not be able to advertise her public key to the community pretending that it is Bob's public key.
- used for internet secure links. Each site has its own public & private keys.
- **Asymmetric-key cryptosystem Model**
 - Both users (Bob & Alice) generates a pair of keys
 - Each user places one of 2 keys in public register.
 - ✓ This is the public key: each user maintains a collection of public keys obtained from others.
 - The companion key is kept private to each.
 - If Alice wishes to send a confidential message to Bob, She encrypts the message using Bob's public key.
 - When Bob receives the message, he decrypts it using his private key.

- ✓ **No other recipient can decrypt** because only Bob knows his private key.

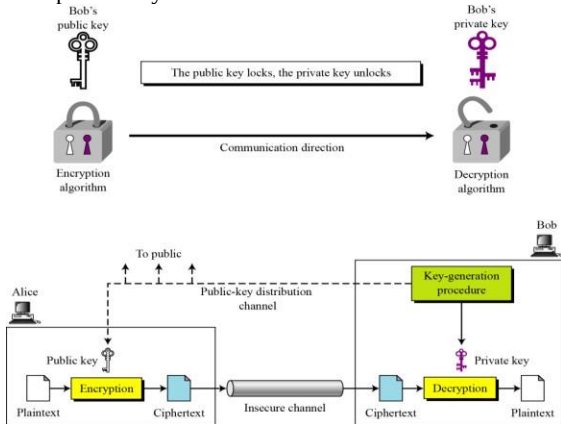


Figure 4.2 Asymmetric-key cryptography

- uses this ideas to make a trap-door one-way function:
 - **dominant PKE** algorithms are based on the difficulty of factoring large numbers, or Discrete Logarithm Problem.
 - Multiplying two large primes is a one-way Function, factoring is conjectured to be a hard problem
- These algorithms are also susceptible to a **brute-force attack**, but of a different type.
- Breaking** these algorithms
 - does not involve trying every possible key;
 - **involves** trying to factor the large number (or taking discrete logarithms in a very large finite field)
- If the **number is too small**, you have no security.
- If number is **large enough**, secured against all computing power.
- Advantages:** more secured, Authentication
- Disadvantages:** relatively complex
- Public Key Infrastructure (PKI)**
 - used for the **management** of public key and **distribution** of digital certificates
 - **Authenticates** users and devices in the digital world.
 - Its most familiar use is
 - ✓ in **SSL certificates** and **TLS** (newer version): in practice, most websites now use TLS.
 - With **HTTPS**, certificates serve to **identify the web site**; ensure no-one can eavesdrop your connection.
 - consists of
 - ✓ Certification Authorities (CAs), Registration Authorities (RAs), Certificate holders, Clients, Repositories, Cryptographic Algorithms and Protocols.
- Examples of Asymmetric key algorithms are as follows:**
 - (1) El Gamal**
 - Developed by Taher ElGamal
 - Variable key size (512 or 1024 bits)
 - Less common than others
 - (2) Diffie-Hellman Key Agreement (DH):**

- **first practical method** for secret share over unsecured channel.
- The point is to agree on a key that two parties can use for a symmetric encryption, in such a way that an eavesdropper cannot obtain the k.
- One of the main uses of DH is in the Internet Key Exchange (IKE) protocol,
 - ✓ a central part of the IP Security (IPSEC) architecture
- **Example:** Suppose Alice and Bob want **to agree on a shared symmetric key**.
 - Alice and Bob, and everyone else, already know the values of p and g .
 - Alice generates a random private value a and Bob generates a random private value b .
 - Both a and b are drawn from the set of integers $1, \dots, p-1$.
 - Alice and Bob derive their corresponding public values, - the values they will send to each other unencrypted-as follows.
 - Alice's public value is $g^a \mod p$ and
 - Bob's public value is $g^b \mod p$ then, they exchange their public values.
 - Finally,
 - Alice computes $g^{ab} \mod p = (g^b \mod p)^a \mod p$ and
 - Bob computes $g^{ba} \mod p = (g^a \mod p)^b \mod p$.

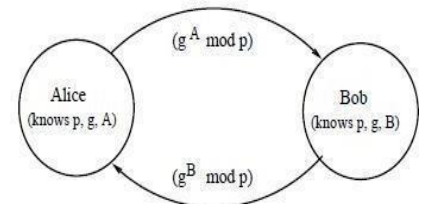


Fig 4.3 Diffie-Hellman Key Agreement (DH)

(3) Rivest, Shamir, Adleman (RSA)

- Developed by Ron Rivest, Adi Shamir, Len Adelman
- Variable Key Size (512, 1024, or 2048 bits)
- Most popular public key algorithm
- **Based on principle:**
 - No mathematical method to efficiently find the prime factors of large numbers
- **Breaking RSA** is equivalent to finding prime factors: this is now to be computationally infeasible.
- private and public keys are constructed from very large prime numbers.
- only who has produced the keys from prime number can easily decrypt messages
- Key Generation, Encryption & Decryption Procedure
 - Choose two large prime numbers p & q
 - Compute $n=pq$ and $z=(p-1)(q-1)$
 - Choose number e , less than n , which has no common factor (other than 1) with z
 - Find number d , such that $ed - 1$ is exactly divisible by z
 - Keys are generated using n, d, e
 - Public key is (n, e)
 - Private key is (n, d)
 - Encryption: $c = m^e \mod n$

- m is plain text
- c is cipher text
- Decryption: $m = c^d \bmod n$
- **Public key is shared and the private key is hidden**

(4) Digital Signature Algorithm (DSA):

- PKI relies on DS, which uses public key cryptography.
- The basic idea is that **private key** is only known by that entity & used **for signing**.
- ✓ **Public key** derived from it: used **for verifying signatures** but cannot be used to sign.
- ✓ It is available to anyone, and is typically included in the certificate document.
- Digital Signature procedure
 - Sender encrypts message with its private key
 - Receiver can decrypt using sender's public key
 - This authenticates sender, who has the matching key
 - Does not give privacy of data i.e. Decrypt key is public key.

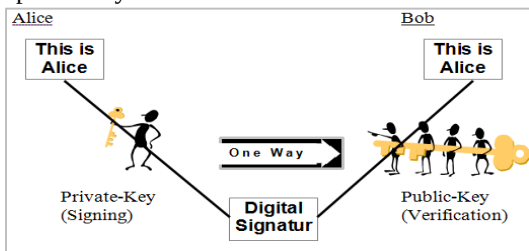


Fig 4.4 digital Signature algorithm (DSA)

Hash functions

- A hash function H takes a variable-size message m as input and produces a fixed-size output, referred to as a hash code or message digest or hash value H(m)
- **no key** is used in this algorithm.
- A **fixed-length hash value** is computed as per the plain text
 - ✓ that makes it impossible for the contents of the plain text to be recovered.
- also used by many operating systems to encrypt passwords..
- **Hashing**
 - ✓ the transformation of **variable-length messages into fixed-length message digest** that represents the original string.
- **Hash value** (or simply **hash**), also called a **message digest**, is a number generated from a string of text.
 - ✓ is much smaller than the text itself.
- creates a **unique, fixed-length signature** for a specific message or data set.
 - ✓ even minor changes to that message result in a dramatically different hash. Therefore, it is very resistant to tampering.

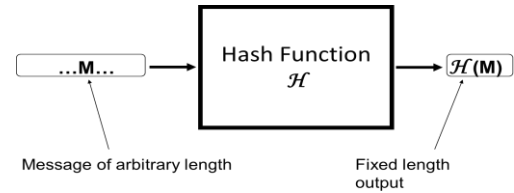


Figure 4.5 Examples of hash algorithms: MD5 , SHA-1

2. Application Security

▪ Vulnerability:

- any **mistakes or weakness in the system security** that may result the possibility for intruders to get unauthorized access

▪ Vulnerability Assessment :

- a software testing technique to **evaluate the sudden increase of risks** involved in the system in order to reduce the probability of the event.
- depends on **two mechanisms**:
 - ✓ **Vulnerability Assessment**: the **process of scanning** (locating & reporting) **vulnerabilities** to provide a way to detect and resolve security problems by ranking the vulnerabilities.
 - ✓ **Penetration Testing**: an authorized **simulated attack** on a computer system, performed **to evaluate the security of the system**.

▪ Types of vulnerability scanner:

- **Host Based :**
 - ✓ Identifies the issues in the host or the system.
 - ✓ carried out by using host-based scanners .
- **Network Based :**
 - ✓ will detect the open port, and identify the unknown services running on these ports.
 - ✓ carried out by using Network-based Scanners.
- **Database Based :**
 - ✓ identify the security exposure in the database systems to prevent from SQL Injections.

▪ Vulnerability Testing Methods:

- **Active Testing**: While doing the test, the tester will actively involve in the process of finding out the new test cases and analyzes the results.
- **Passive Testing**: monitoring the result of running SW under test without introducing new test cases or data.
- **Network Testing**: the process of measuring the state of network operation over a period of time to find out the problems created by new services.
- **Distributed Testing**: applied for testing distributed applications.
- **Penetration Test (pen test)**:
 - ✓ To identify both weaknesses (vulnerabilities) & strengths, to enable a full risk assessment.
 - ✓ Determine whether a system is vulnerable, defenses were sufficient and which defenses (if any) the test defeated.

▪ Secure Shell (SSH):

- A cryptographic protocol for operating NW services securely over an unsecured NW.
 - **Best-known application:** for remote login to computer systems by users.
 - **Common applications:** remote command-line login and execution.
 - **Secure Email:**
 - Adds confidentiality and integrity protection to ordinary e-mail.
 - E.g. **PGP**.
 - **Secure Web servers:**
 - The main vulnerability of web applications is Cross-Site Scripting (XSS).
 - Securing the website or web application itself and the network around it.
 - **Common web servers:** Apache, and IIS.
 - **TLS-based client digital certificates**
 - **Apache or Oracle penetration testing**
 - **VPN Apps**
 - **Application firewall / proxy server**
3. **Firewall**
- a program or network devices (e.g. router) which filters access to a protected network from the internet connection.
 - protects a local or network of systems from network-based security threats,
 - monitors & controls incoming & outgoing network traffic based on predetermined security rules.
 - **Firewall Objectives**
 - Keep intruders, malicious code and unwanted traffic out
 - Keep private and sensitive information in
 - security wall b/n private (protected) NW & outside world.
 - **Categorizes of firewalls**
 - a) **Network firewalls:** Filter traffic b/n two or more networks and run-on NW hardware.
 - ✓ Implemented at a specific point in the network path and protects all computers on the internal side of the firewall from all computers on the external side of the fire wall.
 - b) **Host-based firewalls:** Run on host computers and control network traffic in/out of those machines.
 - a) **Packet Filtering Router:** Examines TCP/IP header information of network data packets going in both directions. Applies set of rules to each incoming IP packets & then forwards or discards the packets.
 - b) **Application-Level Gateway** (application firewall / proxy server): runs special software that acts as a proxy for a service request. Proxy server receives requests for Web pages, accesses the Web server on behalf of the external client, and returns the requested pages to the users.
- c) **Circuit Level Gateway:** Standalone Software that sets up two TCP connections (inside & outside). It determines which connections will be allowed.
- **Firewalls implementation**
 - a) **Hardware firewalls:** a stand-alone product or integrated into the router. It will have a minimum of four network ports to connect other computers.
 - b) **Software firewalls:** installed on your computer and will protect your computer from outside and then determine whether the request is valid or not.
 - c) **Combination of both**
4. **Physical security**
- Without physical security to protect hardware (i.e., doors that lock) nothing else about a computer system can be called secure
5. **Operations security**
- As the software charged with controlling access to the hardware, the file system, and the network, weaknesses in an operating system are the most valued amongst crackers.
 - Most OS authentication is handled through user names and passwords. Biometric (e.g. voice, face, retina, iris, fingerprint) and physical token-based (swipe cards, pin-generating cards) authentication are sometimes used to augment simple passwords, but the costs and accuracy of the technology limit their adoption.
6. **Access control**
- Since many systems (such as router access control lists) define which packets may and which packets may not pass based on the sender's IP address
 - An **access enforcement mechanism** authorizes requests from multiple subjects (e.g. users, processes, etc.) to perform *operations* (e.g., read, write, etc.) on objects (e.g., files, sockets, etc.).
 - **Network access control (NAC):** is an umbrella term for managing access to a net-work. NAC authenticates users logging into the network and determines what data they can access and actions they can perform. NAC also examines the health of the user's computer or mobile device (the endpoints).
 - An operating system provides an access enforcement mechanism.
 - Two fundamental concepts of access control:
 - a **protection system** that defines the access control specification and
 - a **reference monitor** that is the system's access enforcement *mechanism that enforces this specification*.
7. Plan, Design and manage security, security policies, business continuity plans, disaster recovery plans, and social and legal issues of information security
8. Design secure systems for real world information system services